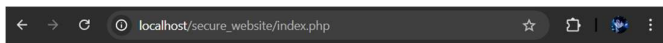


Implementing basic security measures

Basic site

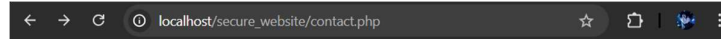


Welcome to My Secure Website

This is a simple PHP website with basic security measures.

[Go to Contact Page](#)

1. Cross Site Scripting Prevention (XSS)



Contact Us

Send

[Back to Home](#)

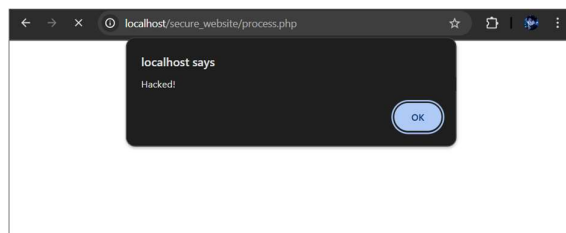
Before

```
process.php
File Edit View
<?php
if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $name = $_POST['name'];
    $message = $_POST['message'];

    echo "<h2>Message Received</h2>";
    echo "<p><strong>Name:</strong> $name</p>";
    echo "<p><strong>Message:</strong> $message</p>";
}
?>
<a href="contact.php">Go Back</a>

Ln 1, Col 1 292 characters 100% Windows (CRLF) UTF-8
```

Injecting script



It tampered with our site

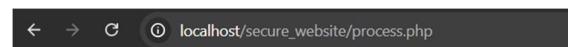
After

```
process.php
File Edit View
<?php
if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $name = htmlspecialchars($_POST['name'], ENT_QUOTES, 'UTF-8');
    $message = htmlspecialchars($_POST['message'], ENT_QUOTES, 'UTF-8');

    echo "<h2>Message Received</h2>";
    echo "<p><strong>Name:</strong> $name</p>";
    echo "<p><strong>Message:</strong> $message</p>";
}
?>
<a href="contact.php">Go Back</a>

Ln 12, Col 1 370 characters 100% Windows (CRLF) UTF-8
```

using "htmlspecialchars()" to filter scripts



Message Received

Name: <script>alert("Hacked!")</script>

Message: hello

[Go Back](#)

now site is reading script as simple text.

2. Implementing Input Validation

```
process.php
File Edit View
<?php
if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $name = trim($_POST['name']);
    $message = trim($_POST['message']);

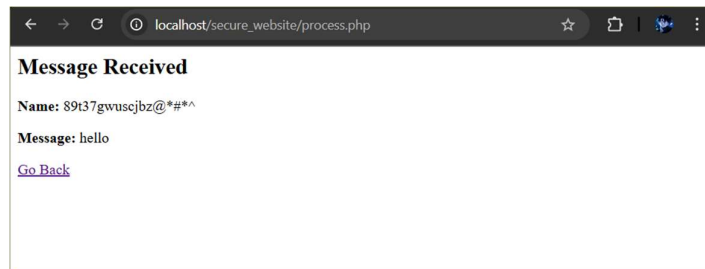
    if (!preg_match("/^[a-zA-Z ]*$/", $name)) {
        die("<p style='color:red;'>Invalid name. Only letters and spaces
are allowed.</p><a href='contact.php'>Go Back</a>");
    }

    if (strlen($message) < 5 || strlen($message) > 500) {
        die("<p style='color:red;'>Message must be between 5 and 500
characters.</p><a href='contact.php'>Go Back</a>");
    }
    $name = htmlspecialchars($name, ENT_QUOTES, 'UTF-8');
    $message = htmlspecialchars($message, ENT_QUOTES, 'UTF-8');

    echo "<h2>Message Received</h2>";
    echo "<p><strong>Name:</strong> $name</p>";
    echo "<p><strong>Message:</strong> $message</p>";
}
?>
<a href="contact.php">Go Back</a>
```

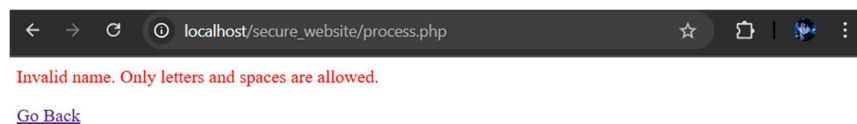
This make sure that only valid input is accepted and also trim out extra character

Before



Also accepting number and special characters in the name input

After



Showing invalid input when taking number in input

3. Enforce HTTPS

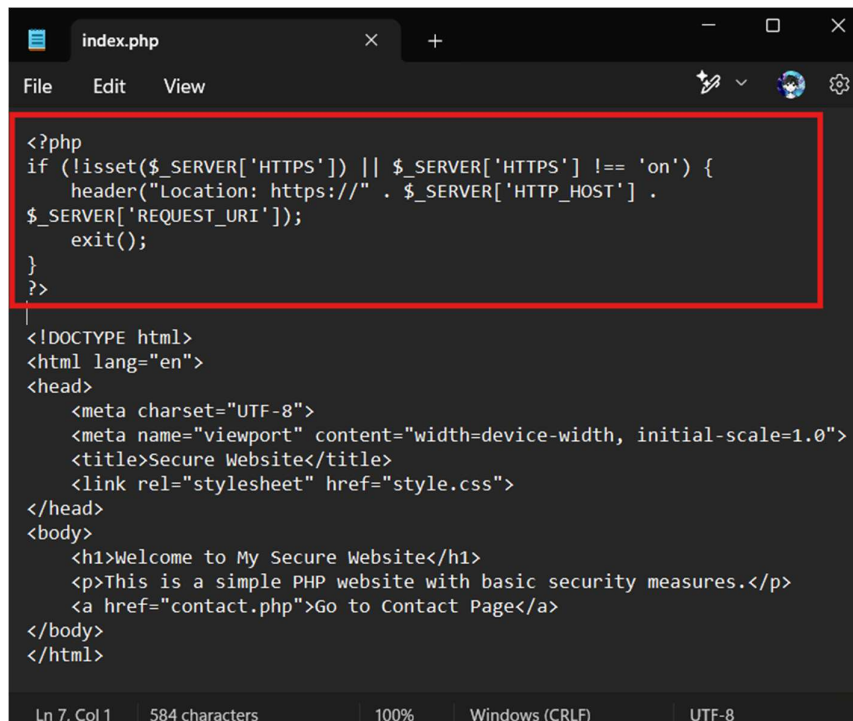
Creating “.htaccess” file in the website folder

```
/*RewriteEngine On
```

```
RewriteCond %{HTTPS} !=on
```

```
RewriteRule ^(.*)$ https://%{HTTP_HOST}/$1 [R=301,L]*/
```

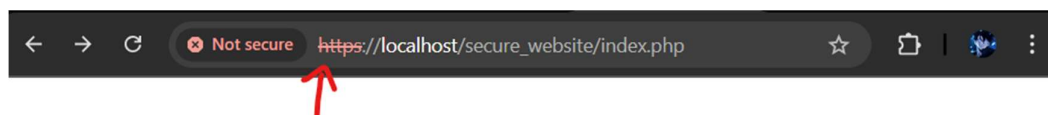
And editing index.php



```
<?php
if (!isset($_SERVER['HTTPS']) || $_SERVER['HTTPS'] !== 'on') {
    header("Location: https://" . $_SERVER['HTTP_HOST'] .
$_SERVER['REQUEST_URI']);
    exit();
}
?>

<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Secure Website</title>
    <link rel="stylesheet" href="style.css">
</head>
<body>
    <h1>Welcome to My Secure Website</h1>
    <p>This is a simple PHP website with basic security measures.</p>
    <a href="contact.php">Go to Contact Page</a>
</body>
</html>
```

Trying to open localhost site with http



Welcome to My Secure Website

This is a simple PHP website with basic security measures.

[Go to Contact Page](#)

Its showing “https” because localhost (XAMPP) doesn’t have SSL certificate by default.